

SkillGuard 安全扫描审计报告

面向银行测试团队的 Agent Skill 准入评估

项目	内容
扫描根目录	C:\Users\vic\Desktop\Scan-Skill-Clean\examples\demo\skills
整体风险	CRITICAL
Skill 数量	1
扫描文件数	3
问题数量	12

风险分布

等级	数量	处置建议
CRITICAL	2	强阻断，必须完成修复或例外审批
HIGH	5	建议阻断，需安全测试或负责人复核
MEDIUM	4	纳入整改计划，评估误报与业务必要性
LOW	1	发布前清理，保持 Skill 可维护

Skill 评分概览

Skill	风险	综合	安全	结构	测试	问题
loan-approval-risk	CRITICAL	37	0	85	80	12

高优先级问题清单

等级	规则	Skill	问题说明	位置
CRITICAL	BANK001	loan-approval-r...	疑似引用银行生产环境或核心系统连接信息	loan-approval-risk/sc...
CRITICAL	BANK002	loan-approval-r...	疑似包含客户敏感信息或金融个人信息	loan-approval-risk/sc...
HIGH	NET002	loan-approval-r...	疑似访问内网、localhost 或云元数据地址	loan-approval-risk/sc...
HIGH	CMD002	loan-approval-r...	存在系统命令执行能力	loan-approval-risk/sc...
HIGH	TEST001	loan-approval-r...	可能删除测试报告、覆盖率或调试产物	loan-approval-risk/sc...

H I G H	D E P 0 0 1	l o a n - a p p r o v a l - r...	存在全局依赖安装，可能污染开发 或测试环境	l o a n - a p p r o v a l - r i s k / s c...
H I G H	M E T A 0 0 8	l o a n - a p p r o v a l - r...	S k i l l 文档未声明网络或接 口访问能力，但实际文件中...	l o a n - a p p r o v a l - r i s k / S K...

银行测试团队落地建议

建议将生产环境连接、客户敏感信息、远程脚本执行、破坏性数据库操作设为强阻断项。H T M L 报告用于逐项复核，P D F 报告用于准入审批和审计归档。

静态扫描不能替代代码评审、沙箱试运行和安全测试；所有高风险 S k i l l 应在无真实凭据、无生产网络访问的隔离环境中验证。